

Website Specifics:

- Dark cyber theme (deep blues/blacks, neon accents for CTAs).
- High-contrast, mobile-first, fast-loading
- Hero animations: Simple swarm visualization or attack graph demo (you can use Grok Imagine or stock cyber visuals).

Trust badges: DPA, Responsible Disclosure Policy, Responsible AI framework, SOC2/PCI readiness signals, "Live Prototype" validation

Responsible Disclosure Policy Content:

Chelys Security operates autonomous penetration testing agents that scan customer systems for vulnerabilities. In the course of authorized testing, these agents may discover vulnerabilities that are previously unknown to the affected software vendor — commonly referred to as zero-day vulnerabilities.

This policy governs what Chelys Security and its customers do when a zero-day or novel vulnerability is discovered during a scan. The core tension is this: the customer hired Chelys to find their weaknesses, and they own the finding — but the vulnerability may exist in third-party software that affects thousands of other organizations who have no idea they are at risk.

This policy resolves that tension by establishing clear roles, a standardized disclosure timeline, and escalation procedures that protect the customer, the affected vendor, and the broader public — in that order of priority.

This policy applies when a Chelys scan produces a finding that meets all three of the following criteria:

1. **Novel:** The vulnerability has no existing public CVE, security advisory, patch, or vendor acknowledgment at the time of discovery.

2. Exploitable: The finding includes confirmed or highly credible evidence of exploitability — not atheoretical weakness. Chelys agents must have either (a) demonstrated exploitation or (b) produced evidence a qualified security researcher would reasonably assess as exploitable.

3. Third-party software: The vulnerability exists in software the customer did not write — a commercial product, open-source library, firmware, or operating system component used by the customer. (Vulnerabilities in the customer's own code are fully the customer's property to handle as they choose.)

Note: Misconfigurations, weak credentials, and unpatched known CVEs are not zero-days under this policy — they are standard pentest findings delivered to the customer with no vendor notification obligations. Only novel, exploitable vulnerabilities in third-party software trigger this policy.

3. Roles and Responsibilities

PARTY	ROLE	OBLIGATIONS UNDER THIS POLICY
Customer	Scan authorizer; primary disclosure decision-maker	Receives the finding first; decides whether to pursue coordinated disclosure or handle privately; must not publicly disclose before the vendor has been notified and given the standard response window; retains final authority over the timing and content of disclosure for their specific instance
Chelys Security	Discovering party; disclosure coordinator	Identifies the finding as a potential zero-day; notifies the customer immediately; provides technical documentation; assists with vendor notification if the customer requests; maintains confidentiality of the finding until disclosure; may escalate to CERT/CC if the vendor is unresponsive and public risk is high
Software Vendor	Affected party; patch developer	Receives notification from customer (with Chelys's technical documentation); expected to acknowledge receipt within 7 days and provide a patch or remediation timeline within 90 days
CERT/CC or Relevant CSIRT	Neutral coordinator (escalation only)	Engaged only if the vendor is unresponsive after 30 days, or if the vulnerability poses imminent, widespread public risk. CERT/CC assists with vendor contact and can help coordinate multi-party disclosure if multiple vendors are affected

4. Discovery Scenarios

Scenario A — Zero-day in Third-Party Software Running on Customer's Systems

Most common

Example: Chelys discovers a remote code execution vulnerability in a specific version of Nginx, Apache Tomcat, or a SaaS SDK the customer uses. The vulnerability is not in the customer's code — it is in the vendor's product.

Who is at risk: The customer and every other organization running the same software version.

Chelys's default action: Notify the customer immediately. Recommend coordinated disclosure to the vendor. Assist the customer with drafting the vendor notification. Follow the 90-day timeline below. If the customer declines to pursue disclosure, Chelys reserves the right to notify CERT/CC if it assesses the public risk as critical.

Scenario B — Zero-day in Customer's Own Product (They Are the Vendor)

Customer-owned finding

Example: Chelys is pentesting a SaaS company and discovers a zero-day in that company's own application — a vulnerability that would affect their end users.

Who is at risk: The customer's own end users and customers.

Chelys's action: This finding belongs entirely to the customer. Chelys delivers it as a standard critical finding. The customer decides whether and how to disclose to their users. Chelys does not contact regulators, the press, or CERT/CC without the customer's consent in this scenario. Chelys recommends the customer engage their own legal counsel on disclosure obligations (particularly if user PII was exposed).

Scenario C — Zero-day Affecting Multiple Vendors or Widespread Infrastructure

High public impact

Example: Chelys discovers a vulnerability in a widely-deployed open-source library (e.g., a cryptography library, a logging framework) that would affect millions of systems if exploited.

Who is at risk: The broader internet.

Chelys's action: Notify the customer. Simultaneously engage CERT/CC as a coordinator (with the customer's knowledge). CERT/CC handles multi-vendor notification. The 90-day timeline applies from the date of CERT/CC engagement. Chelys will not withhold disclosure of a critical, widely-exploitable vulnerability indefinitely at a single customer's request if doing so creates unreasonable risk to the public.

Scenario D — Active Exploitation Detected in the Wild Before Disclosure

Emergency timeline

Example: After Chelys notifies the vendor privately, threat intelligence sources confirm the same vulnerability is being actively exploited in the wild by unknown actors — before a patch is available.

Chelys's action: The 90-day timeline is immediately suspended. Chelys notifies CERT/CC and recommends emergency public disclosure of the vulnerability class (without full exploit details) to allow defenders to implement mitigations. The customer is informed and consulted before any public statement. Full exploit details are withheld until a patch is available or 7 days after public disclosure of the vulnerability class, whichever is sooner.

5. Standard 90-Day Coordinated Disclosure Timeline

Chelys follows the **90-day coordinated vulnerability disclosure** standard established by Google Project Zero and adopted by CERT/CC. The clock starts on the date Chelys notifies the software vendor.

D0

Day 0

Discovery & Internal Triage

Chelys agent flags finding as potential zero-day. Security Lead reviews evidence and confirms it meets the criteria in Section 2. Finding is marked `zero_day_candidate` in the platform and access is restricted to org admin only.

D1

Day 1

Customer Notification (Required within 24 hours)

Chelys notifies the customer via secure channel with: full technical write-up, proof-of-concept evidence, CVSS score, affected component and version, recommended immediate mitigations, and this policy. Chelys recommends the customer apply temporary mitigations immediately while disclosure proceeds.

D7

Day 7

Vendor Notification Deadline

The customer (with Chelys's assistance if requested) sends formal notification to the software vendor's security team. Chelys provides the vendor notification template below. Notification is sent to the vendor's published security contact, `security@[vendor].com`, or via their bug bounty platform if one exists. CERT/CC is CC'd if no vendor security contact can be located.

D14

Day 14

Vendor Acknowledgment Expected

The vendor is expected to acknowledge receipt and confirm they are investigating. If no acknowledgment is received by Day 14, Chelys sends a follow-up. If no response by Day 30, CERT/CC is engaged as a coordinator regardless of customer preference (see Section 6).

D45
Day 45

Patch Timeline Check-In

Chelys requests a patch availability date from the vendor. If the vendor confirms a patch will be available before Day 90, no action is required. If the vendor indicates the patch will take longer than 90 days, a timeline extension of up to 45 additional days (total 135 days) may be granted at Chelys's discretion if: (a) the vendor is actively working on a patch and (b) no active exploitation is detected.

D90
Day 90

Public Disclosure Deadline

Regardless of patch availability, the vulnerability is disclosed publicly on Day 90. If a patch is available, disclosure includes full technical details. If no patch is available, disclosure includes the vulnerability class, affected versions, and available mitigations — but withholds specific exploitation details for up to 14 additional days to give defenders time to apply mitigations. The CVE is requested from MITRE if not already assigned by the vendor.

Post
After

Post-Disclosure

Chelys publishes a security advisory on its website crediting the discovering customer (if they consent) or listing the discovery as "discovered during an authorized Chelys Security scan." The finding is added to Chelys's internal threat intelligence database to improve future detection templates.

CVE (Common Vulnerabilities and Exposures) identifier provides a public, permanent reference for the vulnerability. CVE assignment follows this process:

- 1. Check for existing CVE: Search the NVD and vendor advisories before requesting a new CVE.**
- 2. Vendor requests CVE: The preferred path — the software vendor requests the CVE from their CVE Numbering Authority (CNA). Most major vendors (Microsoft, Apple, Cisco, Red Hat, etc.) are CNAs.**
- 3. CERT/CC requests CVE: If the vendor is not a CNA or is unresponsive, CERT/CC can request the CVE on behalf of the reporting party via the CERT/CC CNA process.**
- 4. MITRE direct request: If neither of the above is possible, submit directly to MITRE at cve.mitre.org/cve/request_id.html. MITRE assigns CVEs as the CNA of last resort.**
- 5. Chelys records the CVE: Once assigned, the CVE is added to the customer's finding record in the platform and included in all public disclosure materials.**

11. Edge Cases and Policy Decisions

What if the customer asks us never to disclose?

For vulnerabilities in the customer's own code (Scenario B), Chelys respects the customer's decision. For vulnerabilities in third-party software affecting the broader public (Scenarios A and C), Chelys will not agree to permanent non-disclosure. If a customer contractually prohibits Chelys from disclosing a critical public-risk vulnerability, Chelys reserves the right to terminate the engagement and engage CERT/CC directly. This position is stated in Chelys's Terms of Service.

What if the vulnerability is already being sold on dark web markets?

If threat intelligence confirms the vulnerability is actively being sold or exploited, the 90-day timeline is immediately suspended and emergency disclosure procedures from the Incident Response Plan (Scenario D) apply. Immediate limited disclosure to CISA and relevant sector ISACs (Information Sharing and Analysis Centers) is authorized without customer approval in this scenario.

What if two Chelys customers independently find the same zero-day?

Chelys will not disclose to either customer that the other has found the same vulnerability. The finding records remain org-isolated per standard multi-tenancy rules. Chelys will coordinate a single vendor notification on behalf of both customers (without revealing either's identity to the other) and will submit a single CVE request.

Responsible AI Framework:

1 Guiding Ethical Principles

Chelys Security is designed around six core principles that govern every architectural decision, from how agents choose targets to how vulnerability data is stored and retained.



Authorization First

No scan may begin without explicit user-confirmed authorization. The platform cannot be pointed at a target the user does not own or have written permission to test.



Scope Containment

Every action taken by every agent is evaluated against a defined scope. Out-of-scope targets are hard-blocked by the Safety Oracle — not soft-warned.



Human Oversight

AI findings are evidence, not verdicts. Humans review, triage, and decide remediation actions. No automated remediation or system changes occur without explicit user approval.



Data Minimization

Only data necessary to produce the security report is retained. Credentials extracted during testing are stored encrypted and purged on schedule.



Full Auditability

Every action — login, job creation, finding update, scope change — is recorded in a tamper-evident audit log with user, IP, and timestamp.



Proportionality

Scan intensity, lateral movement depth, and exploit aggressiveness are bounded by configurable limits. The Safety Oracle prevents actions whose potential harm exceeds testing value.

2 Steps Already Taken — Built & Operational

2A. AI Safety Architecture

The following safety controls are implemented at the agent level and run on every scan:

 Safety Oracle Evaluates every proposed action before execution. Blocks out-of-scope IPs, rate-limit violations, and actions that exceed configured harm thresholds.	 Scope Enforcer Hard-coded scope validation on every target selection. In-scope vs. out-of-scope defined per job; cannot be overridden by AI agents.	 Hop Limiter Lateral movement is capped at 3 hops maximum. Prevents unbounded network traversal during PTH pivot operations.	 Rate Limiter Request rates to scan targets are bounded to prevent accidental denial-of-service during scans.	 Evidence Logger Every tool invocation, result, and AI decision is logged with timestamps. Provides full reconstructable audit of the AI's reasoning chain.
--	--	--	--	---

2B. Authorization & Access Controls

Control	Status	Description
JWT Authentication with refresh tokens	✓ Complete	Stateless auth; tokens expire; refresh rotation on every use
TOTP Multi-Factor Authentication	✓ Complete	TOTP via pyotp; QR enrollment; disable requires current code
Role-Based Access Control (RBAC)	✓ Complete	Admin / Member / Viewer roles; viewers cannot create jobs or modify findings
API Key management with rotation	✓ Complete	Per-org API keys; instant invalidation on rotate
Multi-tenant data isolation	✓ Complete	Every DB row scoped to org_id; queries enforce tenant boundary at ORM level
Audit log — all user actions	✓ Complete	Login, job create/cancel/delete, finding updates, API key rotation — all logged with IP + user agent
Password reset via signed token	✓ Complete	Short-lived HMAC-signed tokens; single-use; expire after 1 hour

Data Categories Collected and Why

Data Category	Purpose	Retention Plan	Status
User account data (email, password hash)	Authentication	Until account deletion	✅ Defined
Scan targets (IPs, domains)	Job execution	Purge 90 days after job deletion	📅 Planned
Vulnerability findings + evidence	Security reporting	User-controlled; max 1 year by default	📅 Planned
Extracted credentials (NTLM hashes, cracked passwords)	Attack path documentation	Purge 30 days after job completion	📅 Planned
Cloud / AD credentials (user-supplied)	Credentialed scan access	Purge immediately on job deletion	📅 Planned
Audit log events	SOC2 compliance, abuse investigation	2 years minimum (SOC2 requirement)	✅ Defined
Agent event logs (tool I/O)	Debugging, evidence reconstruction	90 days; configurable	📅 Planned
PDF reports	Customer deliverable	User-controlled; accessible until deletion	✅ Defined

Privacy Principles Applied

- **Data minimization:** Chelys does not collect marketing analytics, behavioral tracking, or usage telemetry beyond what is necessary to operate the platform
 - **Tenant isolation:** No org can access another org's data — enforced at the database query level on every API endpoint
 - **No third-party data sharing:** Vulnerability data is never shared with third parties, advertisers, or other customers. The only external API calls are to Anthropic (Claude), NVD, and EPSS — none receive raw target data
 - **Anthropic API privacy:** Scan evidence and raw tool output are passed to Claude for report generation. Users should be informed of this in the Privacy Policy. Claude API data is subject to Anthropic's data usage policy
-

PAGES:

1. Homepage (high-conversion landing)
2. Product / Platform
3. Solutions / Use Cases (industry + technical)
4. Pricing (public tiers — critical differentiator vs. many competitors)
5. Resources / Insights (blog, reports, whitepapers, policies)
6. Company / About (team, mission, ethics, investors)
7. Login / Portal (separate app subdomain: app.chelyssecurity.com)
8. Support / Docs (link to validation guide-style content)
9. Contact / Demo (dedicated scheduler)

Navigation (top bar, sticky):

10. Product → (Overview, Features, How It Works, Technology)
11. Solutions
12. Pricing
13. Resources
14. Company
15. [Get a Demo] (prominent button)
16. [Log In]

Footer: Policies (Terms of Service, Responsible Disclosure, Privacy Policy), Trust Center, LinkedIn, etc.

add a Stats Bar:

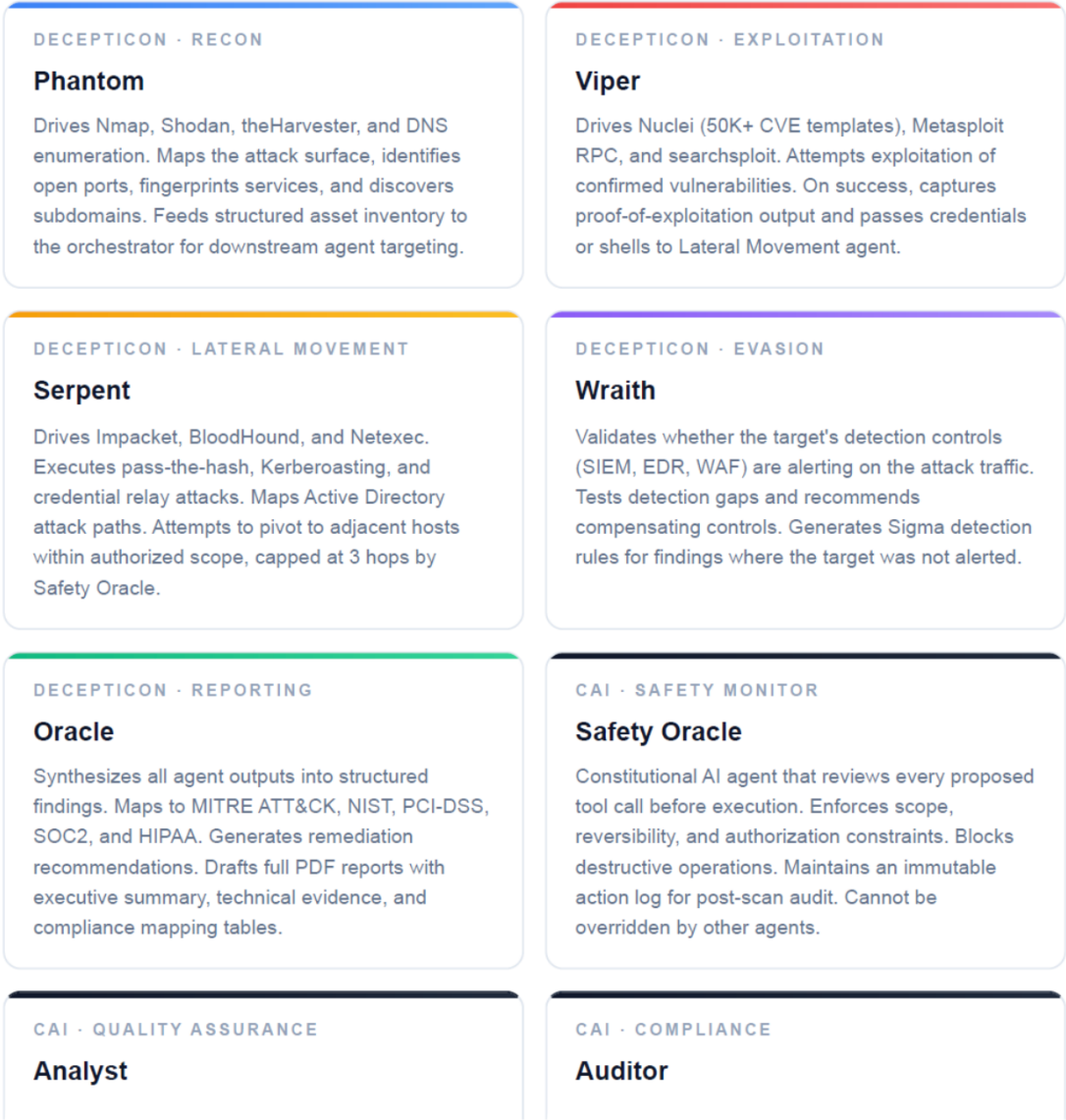
1. 8 AI Agents in Swarm Orchestration
2. 4.3× Performance vs Single-Agent Systems
3. ~\$0.008 Avg. Cost per token input 225K+ Safe Pentests
4. Full SOC2-Ready Controls + Responsible AI Framework

Problem → Solution Section:

Traditional/manual pentests are slow/expensive. NodeZero-style tools are good but lack true AI swarm intelligence and sub-cent economics. Chelys delivers continuous, adaptive testing with Safety Oracle guardrails.

4.1 AI Agent Architecture — 8 Specialized Agents

Chelys does not rely on a single AI agent calling tools sequentially. It deploys **8 specialized agents in parallel** — each with distinct expertise, tools, and objectives. Academic research confirms this is not just a design preference: multi-agent hierarchical teams outperform single-agent approaches by **4.3×** on penetration testing tasks (HPTSA, EMNLP 2025).



for solutions /use cases pages Industry verticals (Finance, Healthcare, Public Sector, MSSP) + technical (Cloud, AD, Kubernetes).

Case study-style cards with metrics from your market/feasibility docs.

Key Market Growth Drivers

The sustained high CAGR in BAS/CART is driven by converging macro trends across the threat landscape, regulatory environment, and enterprise security posture. These tailwinds are structural, not cyclical.

01

AI-Powered Threat Escalation

Nation-state actors and organized criminal groups now leverage AI to accelerate phishing, exploit development, and lateral movement. Security teams must match adversary automation with defensive automation. Gartner's 2026 Top Cybersecurity Trends explicitly calls out AI-driven attack automation as a top board-level concern, directly fueling demand for continuous automated testing.

02

Rising Cost of Data Breaches

IBM's Cost of a Data Breach Report pegged the average breach cost at **\$4.45M in 2023**, rising year-over-year. Organizations are shifting from reactive incident response to proactive continuous validation. A single avoided breach justifies 3–5 years of automated testing spend, creating a compelling ROI case for buyers.

03

Regulatory & Compliance Mandates

PCI-DSS 4.0, SOC 2 Type II, HIPAA, DORA (EU), NIS2, and CISA guidance now require documented, frequent security assessments. Annual manual penetration tests no longer satisfy regulators demanding continuous evidence of control effectiveness. BAS platforms provide the audit trail, continuous validation records, and compliance mapping regulators require.

04

Talent & Cost Scarcity in Manual Testing

There are an estimated **3.5 million unfilled cybersecurity jobs globally** (Cybersecurity Ventures). Skilled penetration testers command \$120,000–\$200,000+ in annual salary, and are in perpetual short supply. Automated platforms let organizations scale security coverage without hiring — a structural, not discretionary, pull toward automation.

05

Cloud & Hybrid Infrastructure Complexity

Cloud adoption introduces dynamic attack surfaces — ephemeral infrastructure, misconfigured IAM roles, exposed S3 buckets, container escape paths — that change daily. Static annual penetration tests cannot track this. BAS platforms provide continuous coverage of cloud-native environments, Kubernetes clusters,

06

Zero Trust Architecture Adoption

Zero Trust mandates (NIST SP 800-207, US Executive Order 14028) require organizations to continuously verify that access controls are functioning as designed — not just configured. BAS platforms are the primary mechanism for validating zero trust implementations continuously, creating a durable, policy-driven demand driver across government and regulated industries.

Competitive Landscape

The BAS/CART market is growing rapidly but remains fragmented. No single vendor holds dominant market share, and the top players each address different technical approaches, customer sizes, and attack coverage areas. This fragmentation represents both a validation of the category and a significant opportunity for a differentiated entrant.

Vendor Comparison Matrix

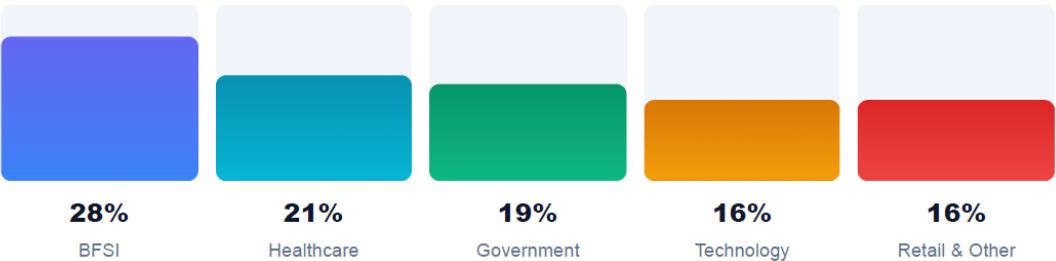
COMPANY	FOUNDED	FUNDING	VALUATION	APPROACH	AI-NATIVE	KEY GAP
Pentera	2015	\$285M+	\$1B+	Agentless autonomous pentest	Partial	No AI reasoning; limited lateral movement chain
Horizon3.ai (NodeZero)	2019	\$186M	Unicorn est.	Autonomous internal pentest	Partial	No agent reasoning; primarily network-focused
AttackIQ	2013	\$95M	—	MITRE ATT&CK simulation library	No	Simulated attacks only; not real exploitation
SafeBreach	2014	\$106M	—	BAS playbook simulation	No	Pre-scripted; cannot adapt to novel environments
Cymulate	2016	\$141M	—	Multi-vector BAS platform	No	No real exploitation; template-driven
XM Cyber	2016	Acq. \$700M	Acquired	Attack path management	Partial	Graph simulation; not actual exploitation

COMPANY	FOUNDED	FUNDING	VALUATION	APPROACH	AI-NATIVE	KEY GAP
Picus Security	2013	~\$45M	—	BAS + threat intelligence	No	Simulation only; no exploitation chain
Chelys Security	2026	—	—	AI-native autonomous swarm pentest	Full	Entrant — see Section 9

Customer Segments & Verticals

Demand for automated security validation is not uniformly distributed. The highest-value customer segments share common characteristics: regulated environments, complex hybrid infrastructure, and recurring compliance requirements that make continuous testing a necessity, not a luxury.

Estimated Market Share by Vertical



Segment-by-Segment Analysis

Banking, Financial Services & Insurance (BFSI) — 28%

The largest and most mature segment. PCI-DSS 4.0, SOX, and banking regulatory exams require documented penetration testing. Large banks run 10–20 assessments annually. Willing to pay premium pricing for continuous coverage. Largest deal sizes in the market (\$150K–\$500K/yr enterprise contracts).

Healthcare & Life Sciences — 21%

HIPAA, HITECH, and FDA cybersecurity guidance drive mandatory testing. Healthcare breaches averaged \$10.9M in 2023 (IBM) — highest of any vertical. Electronic health records, medical IoT, and pharmaceutical IP create complex, high-value attack surfaces. Growing fastest in ransomware targeting.

Government & Defense — 19%

FedRAMP, CMMC 2.0, and US Cyber Executive Orders mandate continuous monitoring and testing for federal contractors and agencies. CISA's "Known Exploited Vulnerabilities" catalog drives remediation verification demand. State and local government increasingly targeted; growing budget category.

Technology & SaaS — 16%

Tech companies face continuous external attack pressure and have sophisticated in-house security teams that prefer automated tooling over manual engagements. Strong product-led growth motion: DevSecOps integration, CI/CD pipeline testing, and bug bounty program augmentation drive land-and-expand.

Ideal Customer Profile (ICP) for Chelys Security

ATTRIBUTE	TIER 1 TARGET	TIER 2 TARGET
Company Size	500–5,000 employees	5,000–50,000 employees
Security Team	5–20 person security team	20+ with dedicated red team
Annual Security Budget	\$1M–\$10M	\$10M–\$100M+
Compliance Drivers	SOC 2, PCI-DSS, HIPAA	FedRAMP, CMMC, ISO 27001
Current Testing	1–2 manual pentests/year	Continuous; augmenting red team
ACV Target	\$12K–\$48K/year	\$50K–\$200K/year

Chelys Security — Strategic Market Opportunity

Chelys Security enters the market at an ideal moment: when the category has been validated by public company exits and unicorn funding rounds, but when no incumbent has yet delivered a truly AI-native, autonomous, swarm-orchestrated penetration testing platform with the economics to serve the mid-market at scale.

Structural Advantages vs. Incumbents

AI-Native Architecture

Built on Claude's extended thinking and multi-agent orchestration from the ground up — not retrofitted. Incumbents like Pentera and NodeZero apply heuristic automation; Chelys applies genuine AI reasoning to adapt attack chains in real time based on what it discovers.

Economics: \$0.004–\$0.01 Per Scan

Chelys's AI-driven approach collapses the cost of a scan to fraction-of-a-cent economics, enabling pricing that democratizes continuous testing for the mid-market — an underserved segment every incumbent ignores in favor of enterprise-only pricing starting at \$50K+/yr.

Autonomous Swarm Orchestration

Five specialized Decepticon agents (reconnaissance, exploitation, lateral movement, evasion, reporting) operate in parallel — not sequentially. This delivers 3–5× more coverage per scan than single-agent approaches and enables genuine multi-hop attack chain discovery that no existing BAS tool replicates.

Integrated Compliance Reporting

Findings are automatically mapped to MITRE ATT&CK, NIST, PCI-DSS, SOC2, HIPAA, and ISO 27001 frameworks — a feature that typically requires separate GRC tooling. This increases deal size and reduces churn by making Chelys sticky across the compliance workflow, not just the testing workflow.

Bug Bounty Mode & MSP Channel

Dedicated bug bounty mode enables a unique go-to-market through security researchers and MSP channel partners — an acquisition channel incumbents don't address. Reseller flag and white-labeling capability built in from day one enables rapid channel revenue without a large direct sales team.

Living Attack Graph

Unlike static scan reports, Chelys maintains a continuously updated attack graph — showing how discovered vulnerabilities chain together into exploitable attack paths. This graph-based view of risk is what security leaders need to prioritize remediation and is absent from every BAS platform currently available.

TIER	TARGET	ACV	SCAN QUOTA	GROSS MARGIN
Starter	Mid-market (50–500 employees)	\$3,588/yr (~\$299/mo)	5 scans/mo	>90%
Pro	Enterprise (500–5,000)	\$11,988/yr (~\$999/mo)	30 scans/mo	>88%
Enterprise	Large enterprise / MSSP	Custom (\$50K–\$200K)	Unlimited	>85%